Redline Stealer Demonstration Planning

Table of Contents

Scenario 2: "The Infostealer Leak" (Walk-in Client)..... 2

1. Overview..... 2
    1.1 Attack Chain Summary..... 2
2. Lab Setup..... 2
    2.1 Infrastructure..... 2
    2.2 Logging Configuration..... 2
    2.3 Test Data (all mock)..... 2
3. Attack Simulation..... 3
    3.1 Phase 1: Initial Payload Hosting..... 3
    3.2 Phase 2: Payload Delivery..... 3
    3.3 Phase 3: Data Collection..... 3
    3.4 Phase 4: Command and Control..... 3
    3.5 Execution Sequence..... 3
4. Investigation (Walk-in Walkthrough)..... 4
    4.1 Engagement Flow..... 4
    4.2 Analysis by Artifact..... 4
    4.3 Ground-Truth Queries (Appendix only)..... 5
    4.4 Alerting..... 5
5. Findings and Recommendations..... 5
    5.1 Findings (Demonstrated on Dummy Accounts)..... 5
    5.2 Recommendations and Revocation Priorities (Demonstrated on Dummy Accounts)..... 6
6. Conclusion..... 6

Appendix..... 6

Scenario 2: "The Infostealer Leak" (Walk-in Client)

1. Overview

1.1 Attack Chain Summary

- **Initial access:** malvertising. A sponsored search result for a "free PDF converter" leads to a fake download page.
- **User interaction:** the designer downloads and runs **PDFConverter_Setup.exe**.
- **Execution:** a benign dummy payload runs from the user's Temp folder.
- **Data targeted:** dummy browser credentials and cookies, and a dummy Telegram session folder, the two most common RedLine-style targets.
- **Exfiltration:** the data is zipped and sent over HTTP to an external "C2" (a Kali listener).
- **Persistence:** a user-level Run key.

2. Lab Setup

2.1 Infrastructure

Component	Purpose
Windows VM	Victim laptop (25-staff creative agency)
Kali	Fake download page + Python HTTP listener (C2)
Forensic workstation	KAPE, WinPmem, FTK Imager, Wireshark, Plaso, Timeline Explorer, TheHive
Sysmon + Splunk (on the victim VM)	**Ground truth only.** Not shown to the investigator and not part of the service

2.2 Logging Configuration

The client has **no monitoring or logging**, since this is a walk-in. The investigator works only from what the collection kit gathers. Sysmon and Splunk exist only to confirm afterward that nothing was missed.

2.3 Test Data (all mock)

Login Data and Cookies placeholder files with fake accounts, including the agency's marketing account

- A placeholder Telegram tdata folder with dummy session files
- A fake system profile (hostname, OS)

3. Attack Simulation

3.1 Phase 1: Initial Payload Hosting

- **3.1.1 Fake download page:** a simple page on Kali styled as a PDF converter site. The user clicks Download. (No clipboard trick is used in this scenario.)
- **3.1.2 Payload staging:** the dummy installer is hosted as PDFConverter_Setup.exe with no special permissions.

3.2 Phase 2: Payload Delivery

- **3.2.1 Behavior:** after download, the user runs the file. Windows tags it with a Zone.Identifier (internet origin).
- **3.2.2 Secondary payload:** not used. A single dummy executable keeps the demo clear.

3.3 Phase 3: Data Collection

- **3.3.1 Actions:** the payload creates a hidden staging folder in %LocalAppData%\Temp (use a realistic name such as ~dfx_cache, not "RedLineExfil"). It copies the mock browser and Telegram files in, then zips them. The payload never reads a real browser or Telegram database; it only copies the placeholder files from 2.3.
- **3.3.2 Target data:** browser credentials and cookies, and the Telegram session folder.

3.4 Phase 4: Command and Control

- **3.4.1 C2 server:** a Python HTTP listener on Kali. It logs timestamp, source IP and payload size, and saves the received zip. Note that while real RedLine uses SOAP over TCP or HTTP, this lab uses simple HTTP for ease of demonstration.
- **3.4.2 Reverse shell:** not used.
- **Behavior:** a beacon every 60 s, one POST of the zip, then it stays running so memory capture has something to find.

3.5 Execution Sequence

- Fake page served and installer downloaded
- Staging folder and zip created

- Run key present
- Listener received the beacon and the zip
- Payload still running at memory capture

4. Investigation (Walk-in Walkthrough)

4.1 Engagement Flow

#	Stage	What happens	Output
1	Trigger	The owner gets an overseas login alert on the marketing account (a scripted event in the demo) and calls the hotline	Call record
2	Intake	A TheHive case is opened with a unique ID and rated **P1**	Case ID
3	Authorization	One e-signature covers NDA, terms and system authorization. The deposit is paid at the burst rate. **The SLA clock starts.**	Signed authorization, receipt
4	Containment	The client changes passwords and revokes sessions from a clean device, and disconnects the laptop without rebooting it. Their security tools stay enabled.	Signed checklist
5	Collection	The allowlisted kit runs KAPE triage, WinPmem memory capture, a 15-minute Wireshark capture, and an FTK disk image if time allows. Everything is hashed at source, uploaded and verified.	SHA-256 manifest, custody log
6	Analysis	Work is done on copies only, using the artifact checks in 4.2	Timeline, IOCs
7	Ground-truth check	Findings are compared with the Sysmon/Splunk log (lab only)	Coverage check
8	Reporting	The Unified Forensic Report is written, peer-reviewed, published and walked through	Report
9	Closure	Evidence is retained for 12 months, then deleted with certification. The client is offered a subscription.	Closed case

4.2 Analysis by Artifact

Area	What the investigator looks for
Process (memory, prefetch)	The payload running from Temp, its start time and its parent
Network (pcap, memory)	The 60 s beacon, the POST and its size, and the external IP
File system (Plaso timeline)	The download, the hidden staging folder, the zip, and mock files copied from browser and Telegram paths
Persistence (registry)	The Run key pointing to a user-writable path
Origin (browser history, Zone.Identifier)	The fake search ad and download URL

4.3 Ground-Truth Queries (Appendix only)

Conceptual structure: Sysmon process creation (payload path), network connection (to the C2 IP), file creation (staging folder, zip) and registry value set (Run key). The exact queries are in the appendix.

4.4 Alerting

Not applicable. Monitoring is excluded from our scope (SLA 4.2.9). Instead, the report recommends the client set up logging and alerting, and offers our **log readiness setup** add-on.

5. Findings and Recommendations

5.1 Findings (Demonstrated on Dummy Accounts)

Finding	ATT&CK
Malvertising download	T1583.008
User ran the installer	T1204.002
Browser credential theft	T1555.003
Cookie and session theft	T1539

Finding	ATT&CK
Data zipped before exfiltration	T1560.001
Run key persistence	T1547.001
Exfiltration over HTTP C2	T1041, T1071.001

Gaps: no logging, no EDR, no download protection, and the account lacked MFA.

5.2 Recommendations and Revocation Priorities (Demonstrated on Dummy Accounts)

1. Reset the marketing account and all browser-saved passwords, and kill active sessions (stolen cookies bypass passwords).
2. Terminate all Telegram sessions and re-enable 2FA.
3. Reimage the laptop and enable MFA on every account.
4. Turn on logging, block cracked or freeware installers, and train staff on malvertising.
5. Book the 30-day post-incident re-check.

6. Conclusion

- **Summary:** this scenario demonstrates the walk-in flow from first call to closed case, reaching an evidence-backed report using only the collection kit.
- **Takeaways:** work on copies, hash everything and state findings only where the evidence supports them.
- **Next steps:** convert the walk-in client to a subscriber.

Appendix

- **A. Tools:** KAPE, WinPmem, FTK Imager, Wireshark, Plaso, Timeline Explorer, TheHive, Python listener, Sysmon, Splunk (ground truth).
- **B. References:** ATT&CK technique pages (IDs above)
- **C. Glossary:** IOC, C2, Zone.Identifier, malvertising, super-timeline, chain of custody.